

Kristi Talving
Tarbijakaitse ja Tehnilise Järelevalve Amet
info@ttja.ee
Endla 10A
10122 Tallinn, Harju maakond

MÄRGUKIRI

07.04.2026

Lugupeetud peadirektor

Käesolevaga edastame Tarbijakaitse ja Tehnilise Järelevalve Ametile märgukirja seoses SK ID Solutions AS-i poolt pakutava Smart-ID teenuse turundamisega. Avalikult kättesaadav tehniline dokumentatsioon ning sõltumatud tehnilised analüüsid viitavad sellele, et Smart-ID turundustegevus on vastuolus toote tegeliku tehnilise ülesehitusega. See loob eeldused tarbijate eksitamiseks ning viib küberintsidentide korral vastutuse ebaõiglaselt üle tarbijatele ja e-teenuse pakkujatele.

1. Asjaolud ja tehniline taust

SK ID Solutions AS turundab Smart-ID teenust tarbijatele kui maksimaalselt turvalist ja eIDAS määruse kohaselt kõrgeima usaldusväärsuse tasemega autentimis- ja allkirjastamisvahendit. Teenus on muutunud Eesti digitaalse infrastruktuuri üheks alustoeiks.

Vaatamata tarbijatele suunatud absoluutse turvalisuse turundussõnumitele, selgub ettevõtte enda poolt avaldatud e-teenuse pakkujatele suunatud liidese (Smart-ID RP API v3) dokumentatsioonist järgmine:

Turvanõrkuse teadlik lubamine: Dokumentatsioonis eksisteerib teavitusepõhine autentimisvoog, mis on juhendis märgitud kui mittesoovitav.

Õngitsusrünnete oht: SK ID Solutions mõonab dokumentatsioonis otseselt, et nimetatud meetodi puhul tugineb kaitse õngitsusrünnete vastu üksnes kasutaja teadlikkusel. See on olemuslikult haavatav vahendajarünnakutele ja mitmefaaktorilise autentimise kurnamise rünnete.

Turvalisema alternatiivi varjamine tarbijate eest: Samas liidese on olemas seadmega seotud autentimisvoog ehk kontrollkoodiga seotud lahendus, mis pakub maksimaalset kaitset õngitsuste vastu.

Vastutuse vältimise strateegia: SK ID Solutions AS delegeerib turvariskide hindamise e-teenuse pakkujale, sõnastades juhendis, et riske peab hindama teenusepakkuja. Kuna tarbijatele on toodet turundatud kui aligupäraselt ohutut, langeb ründe õnnestumisel tegelik rahaline ja moraalne kahju tarbijale, samas kui

tehnoloogia looja on end lepinguliselt vastutusest vabastanud.

Võrdlusena on Põhjamaade BankID läbinud sarnase kriisi, kus finantsjärelevalve ja küberkaitseasutuste survele oldi sunnitud pettuste vältimiseks minema üle eranditult turvalisematele voogudele nagu animeeritud ruutkood ja rakendustevaheline koodisidumine.

2. Õiguslik alus

Eelnevalt kirjeldatud praktika läheb vastuollu mitmete Eesti ja Euroopa Liidu õigusaktidega:

2.1. Tarbijakaitseseadus (TKS)

§ 15 (Ebaaus kauplemisvõtte): Kauplemistava on ebaaus, kui sellega antakse tarbijale valeandmeid toote peamiste omaduste või riskide kohta. Smart-ID turundamine kompromissitult turvalise teenusena, omades samal ajal teadaolevat ja madala turvalisusega autentimisvoogu, moodustab ebaausa kauplemisvõtte.

§ 16 (Eksitav kauplemisvõtte): SK ID Solutions AS jätab tarbijakommunikatsioonis märkimata olulise teabe selle kohta, et teatud süsteemiintegratsioonide puhul on tehniline kaitse eemaldatud ning turvalisus taandatud üksnes tarbija teadlikkusele, mida tavakasutaja ei pruugi stressi- või ründeolukorras märgata. Selline olulise teabe varjamine on käsitletav eksitava tegevusetusena.

2.2. Võlaõigusseadus (VÕS)

§ 62 primm 7 lõike 3 punkt 2 (Digitaalse sisu ja digitaalse teenuse vastavus lepingutingimustele): Tarbijale pakutav digiteenus peab olema seda liiki digitaalsele teenusele tavaliselt omase kvaliteedi ning tavaliste toimivusomadustega, sealhulgas turvalisuse poolest, mida tarbija võib mõistlikult eeldada. Tarbija teadlikkusele veeretatud turbemudel ei vasta tarbija õigustatud ootustele riiklikult tunnustatud e-identiteedi ja pangakontosid kaitsva vahendi suhtes.

2.3. eIDAS määrus ja Isikuandmete kaitse üldmäärus (GDPR)

Kvalifitseeritud usaldusteenuse osutajad peavad vastavalt eIDAS määrusele (sealhulgas määruse 2024/1183 uuendustele) rakendama tehnika uusimale tasemele vastavaid turvameetmeid. Isikuandmete kaitse üldmääruse artikkel 25 nõuab lõimitud ja vaikinisi andmekaitset. Teadlikult vananenud ja nõrga autentimisvoo avatuks jätmine lepingulise vastutusest vabanemise varjus on nende põhimõtetega vastuolus.

3. Tarbijaõiguste rikkumise ulatus

Smart-ID teenust kasutatakse igapäevaselt pangandustoiminguteks, riigi teenustesse sisselogimiseks ja õiguslikku siduvust omavate dokumentide allkirjastamiseks. Olukorras, kus tarbija kasutab teenusepakkuja juures teavitusepõhist voogu ja satub ründe ohvriks, kannab tarbija reaalselt finantskahju. SK ID Solutions AS on samal ajal end vastutusest vabastanud, mis viib tarbija äärmiselt kaitsetusse positsiooni.

4. Taotlus ja ettepanekud asutustele

Tuginedes eeltoodule, palume Tarbijakaitse ja Tehnilise Järelevalve Ametil:

Alustada riiklikku järelevalvemenetlust SK ID Solutions AS suhtes Tarbijakaitseseaduse § 15 ja § 16 alusel, et tuvastada eksitava kauplemistava esinemine Smart-ID teenuse turundamisel.

Teha SK ID Solutions AS-ile ettekirjutus, milles nõutakse:

- a) Tarbijate otsest ja läbipaistvat teavitamist madalama turvatasemega autentimisviiside ohtudest;
- b) Tehniliste meetmete rakendamist, et muuta e-teenuse pakkujatele vananenud ja nõrkade autentimisvoogude kasutamine võimatuks või asendada need vaikimisi seadmega seotud turvalisemate meetoditega.

Teha menetluslikku koostööd Riigi Infosüsteemi Ameti ja Andmekaitse Inspeksiooniga, arvestades, et antud kaasuses põimuvad e-identiteedi usaldusteenuse nõuded, isikuandmete turvalisus ja tarbijate majanduslikud huvid.

Kinnitame valmisolekut pakkuda vajadusel täiendavaid tehnilisi selgitusi dokumentatsioonis esinevate tehnoloogiliste voogude kohta.

Ootame teie seisukohta käesolevas pöördumises toodud asjaolude kohta seaduses ettenähtud tähtaja jooksul.

Palun vastata mulle kirjalikult e-postiga.

Lugupidamisega

(allkirjastatud digitaalselt)

Tom Kristian Abel
Märgukirja esitaja

Lisad:
